

Security Risk Assessment: Wareshore

A made-up company, assessed using the NIST Cybersecurity Framework (CSF)

What this is

I picked a small made-up company and looked at what could go wrong with its security. I scored each risk, matched it to a NIST function, and wrote one fix for each. The company is called Wareshore.

The short version: Wareshore holds private customer data and has almost no protection around it. The first things to fix are 2FA, logging, and public cloud storage.

The company

Wareshore sells cheap inventory management software to small startups that can't pay for big enterprise tools. It has 15 employees and runs on Google Cloud.

The system stores stock levels, supplier contracts, customer orders, and shipping addresses. The addresses belong to real people, so a leak isn't only a business problem.

What's weak right now:

- no 2FA
- no logging or monitoring
- backups were never tested
- admin passwords are shared
- no incident plan
- nobody keeps a list of who has access to what

How I scored

Score = likelihood x impact, both from 1 to 5.

- Likelihood: how easy or probable it is. 1 is very unlikely, 5 is expected within months.
- Impact: how bad the damage is. 1 is barely noticed, 5 could end the company.
- 15 to 25 is High, 8 to 14 is Medium, 1 to 7 is Low.

The NIST CSF has six functions: Govern, Identify, Protect, Detect, Respond, Recover. I tagged each risk with one.

Risk table

#	Risk	L	I	Score	Function
1	No 2FA, so a phishing attack can take over an account	5	4	20 High	Protect
2	No logging, so a breach goes unnoticed	4	4	16 High	Detect
3	Cloud storage accidentally left public	3	5	15 High	Protect
4	Backups never tested	3	4	12 Medium	Recover
5	Shared admin passwords, ex-employees keep access	3	4	12 Medium	Protect
6	No incident plan	4	3	12 Medium	Respond
7	A connected partner gets hacked	3	4	12 Medium	Govern
8	No list of systems, data, and access	4	3	12 Medium	Identify
9	Laptops not encrypted	3	3	9 Medium	Protect
10	Anyone can edit stock and orders	2	3	6 Low	Protect

The three High risks

1. No 2FA. Phishing tricks a person into typing their password into a fake login page. Waresore's staff have no security training, and with no second step a stolen password is enough to get in. That's why likelihood is 5. Once inside, the attacker can read orders, inventory, internal information, and shipping addresses, so impact is 4. It isn't 5 because one account doesn't show everything at once and the company would survive it.

Fix: Turn on 2FA for admin accounts first, then for everyone.

2. No logging. Missing logs don't cause a breach, but they make one much harder to catch, and the damage can go on for weeks. Likelihood is 4 because with this many gaps a breach is likely, and nobody would notice. Impact is 4 for the same reason.

Fix: Turn on logging in Google Cloud and set alerts for logins from strange places or large downloads.

3. Public cloud storage. This is an easy mistake to make, and it's easy for someone to find, so likelihood is 3. Impact is 5 because the storage holds supplier contracts and customer shipping addresses, and the information could be posted online without anyone at Waresore knowing.

Fix: Make storage private by default and check the settings every month.

The medium and low risks

4. Backups never tested (3 x 4). The backups might work, but nobody knows. If they fail, customers can't ship for days. It hurts a lot, but a small company would survive, so I didn't give it a 5. *Fix:* back up daily and test a restore every month.

5. Shared admin passwords (3 x 4). When someone leaves, shared passwords mean their access never really goes away, and admin access is powerful. *Fix:* give everyone their own login and remove access within 24 hours of someone leaving.

6. No incident plan (4 x 3). The missing plan doesn't cause attacks, but staff wouldn't know what to do, so the response would be slow. *Fix:* a short plan where the CTO leads, customers are told if their data is affected, and every staff member knows it.

7. Partner gets hacked (3 x 4). Waresore can't control its partners' security, and attackers can get in through them. *Fix:* check a partner's security before connecting them and give them only the data they need.

8. No access list (4 x 3). New tools and accounts get added casually, and nobody tracks them. It doesn't leak data on its own, but it hides other problems. *Fix:* keep a simple list of systems, where data lives, and who has access, and review it every six months.

9. Unencrypted laptops (3 x 3). Laptops get lost or stolen. Most data is in the cloud so the damage is limited, but saved logins and local files could be read. *Fix:* turn on disk encryption on every company laptop.

10. Anyone can edit stock and orders (2 x 3). It would take a bad insider or an attacker, so it's unlikely. The damage is wrong shipments and lost trust, not a data breach. *Fix:* give staff the minimum access they need and keep a record of every change.

What to do first

- **First 30 days:** 2FA, private storage, individual logins.
- **By 60 days:** logging with alerts, and the incident plan.
- **By 90 days:** backup tests, laptop encryption, edit limits, the access list, and the partner checklist.

I started with 2FA because it's cheap and blocks the most likely attack.

Limits

These scores are my own estimates for an imaginary company, with no real testing behind them. Govern is covered by only one risk, and a longer assessment would also look at security policies and who owns security. After the fixes, the scores should be checked again.